Môn: Điện toán đám mây
Mã lớp học phần: 012012303904

Thiết kế và kiểm chứng kế hoạch phục hồi sau thảm họa cho ứng dụng cloud native

Người trình bày:
Hoàng Việt Quang-066206005044
Nguyễn Minh Thư-082306008557
Lê Thị Lan Hương-052306007313

Kiến trúc: một cụm chạy, ba nơi giữ bản sao

Cụm chính

K3s trên Azure, Hàn Quốc
web, API, PostgreSQL

Kho sao lưu ở Nhật

WAL, bản đầy đủ, Velero, bản chép ảnh

Cụm dự phòng

Hàn Quốc; chạy sẵn khi dùng dự phòng ấm

Két chống xóa ở Nhật

WORM 7 ngày, gói mã hóa bằng age

Máy chủ ngoài Azure

Kéo gói từ két mỗi đêm qua Tailscale

Đổi máy chủ cho tên miền API bằng Cloudflare DNS (TTL 60 s). Mã nguồn và image nằm trên GitHub, ngoài Azure.

Kế hoạch trên giấy có đạt RTO, RPO thật không?

Câu hỏi nghiên cứu: một kế hoạch chưa từng được diễn tập thì chưa biết có khôi phục kịp hay không. Nhóm đặt mục tiêu, dựng hệ thống, rồi phá thật và đo.

60 phút

RTO dự phòng nguội: dựng cụm mới từ bản sao lưu

10 phút

RTO dự phòng ấm: chuyển sang cụm dự phòng đang chạy

5 phút

RPO bài viết và ảnh: dữ liệu mất tối đa

RTO (recovery time objective): thời gian tối đa được phép ngừng. RPO (recovery point objective): lượng dữ liệu tối đa được phép mất, tính theo thời gian. Nguồn: NIST SP 800-34 Rev. 1.

Đánh giá ảnh hưởng nghiệp vụ (business impact analysis - BIA)

BIA là bước cốt lõi trong quy trình lập kế hoạch dự phòng hệ thống thông tin. BIA giúp xác định, phân loại và ưu tiên các quy trình nghiệp vụ quan trọng của tổ chức, từ đó đánh giá mức độ ảnh hưởng và thiệt hại khi ứng dụng hoặc tài nguyên hệ thống bị gián đoạn. (NIST SP 800-34 Rev. 1)

Các bước thực hiện BIA:

- Xác định quy trình nghiệp vụ và mức độ quan trọng: Liên kết ứng dụng với các quy trình nghiệp vụ cốt lõi và đo lường mức độ thiệt hại (tài chính, pháp lý, uy tín) nếu xảy ra sự cố.
- Xác định yêu cầu tài nguyên: Liệt kê đầy đủ các tài nguyên phụ thuộc (máy chủ, dữ liệu, phần mềm, kết nối mạng) cần thiết để khôi phục nghiệp vụ.
- Thiết lập thứ tự ưu tiên khôi phục: Sắp xếp thứ tự phục hồi cho các thành phần hệ thống dựa trên mức độ ảnh hưởng nghiệp vụ.

Phân tích ảnh hưởng nghiệp vụ

Thành phần	Nếu mất thì	RPO	RTO nguội / ấm
Cơ sở dữ liệu bài viết	Không đọc, không đăng được bài	5 phút	15 phút / 2 phút
Kho ảnh	Bài hiện mà ảnh lỗi	5 phút	15 phút / 2 phút
Cấu hình triển khai	Không dựng lại được dịch vụ	1 giờ	15 phút / có sẵn
Cả trang web	Người dùng không vào được	5 phút	60 phút / 10 phút

RPO 5 phút dựa vào nhật ký thay đổi (WAL) đẩy đi tối đa mỗi phút và việc Azure tự chép ảnh (đo được p95 129 s).

Nguyên tắc sao lưu dữ liệu an toàn

Sao lưu nhất quán ở mức ứng dụng (application-consistent backup): là phương pháp sao lưu nâng cao, hệ thống không chỉ chụp lại các file trên đĩa cứng mà còn phối hợp trực tiếp với ứng dụng để đảm bảo toàn bộ dữ liệu trong bộ nhớ RAM và các giao dịch đang xử lý dở dang được hoàn tất và ghi xuống đĩa an toàn trước khi tiến hành sao lưu

Snapshot nhất quán của cơ sở dữ liệu (database-consistent snapshot): là bản chụp nhanh toàn bộ dữ liệu của CSDL, tại một mốc thời điểm chính xác, đảm bảo mọi giao dịch, bảng dữ liệu, chỉ mục (indexes) và nhật ký giao dịch (transaction logs) hoàn toàn khớp nhau và không bị dở dang

Bản sao lưu không thể sửa, xóa (immutable backup): là cơ chế bảo vệ dữ liệu sao lưu theo nguyên tắc WORM (write once, read many). Sau khi bản sao lưu được tạo ra, nó bị "khóa" hoàn toàn - không bất kỳ ai (kể cả tài khoản quản trị cao nhất như Admin/Root) có thể chỉnh sửa, ghi đè hoặc xóa bản sao lưu đó trong suốt khoảng thời gian lưu giữ (retention period) đã thiết lập

Mã hóa bản sao lưu (backup encryption): là quá trình chuyển đổi toàn bộ dữ liệu sao lưu từ dạng văn bản rõ (plaintext) sang dạng mật mã bí ẩn (ciphertext) bằng các thuật toán mã hóa tiêu chuẩn (như AES-256). Khi đã được mã hóa, nếu không có "chìa khóa giải mã" (decryption key) hợp lệ, bất kỳ ai lấy được tệp sao lưu cũng chỉ nhìn thấy một chuỗi ký tự vô nghĩa và không thể xem hay trích xuất được thông tin bên trong.

Quy tắc sao lưu 3-2-1

Quy tắc 3-2-1 là nguyên tắc sao lưu phổ biến để dữ liệu vẫn khôi phục được khi một nơi lưu trữ hỏng hoặc bị xóa. Nguồn: Krogh (2009); US-CERT (2012).

- 3 bản dữ liệu: bản gốc đang chạy và 2 bản sao lưu.
- 2 phương tiện lưu trữ khác nhau, để một lỗi không làm hỏng cả hai bản.
- 1 bản ở nơi khác, còn nguyên khi cả trung tâm dữ liệu gặp sự cố.
- Đồ án áp dụng bằng ba miền lỗi khác nhau: kho sao lưu ở Nhật, két chống xóa, máy chủ ngoài Azure.

Sao lưu ba tầng theo quy tắc 3-2-1

1

Kho sao lưu ở Nhật

• WAL đẩy liên tục, tối đa mỗi phút
• Bản đầy đủ mỗi 6 giờ, Velero mỗi giờ
• Ảnh được Azure tự chép sang Nhật

Khôi phục hằng ngày

2

Két chống xóa

• Chính sách WORM 7 ngày, đã khóa cứng
• Gói mã hóa bằng age trước khi rời cụm
• Không ai xóa được, kể cả chủ tài khoản

Chống mã độc tống tiền

3

Server ngoài Azure

• Tự kéo gói từ két mỗi đêm
• Không giữ khóa giải mã
• Dùng khi mất cả tài khoản Azure

Chống mất nhà cung cấp

Đo từng bước, không đoán

Phát hiện

Quyết định

Dựng hạ tầng

Khôi phục dữ liệu

Kiểm tra

Đổi DNS

- Công cụ azure_drill gọi /healthz mỗi giây và ghi mốc thời gian của từng bước vào CSV.
- Sau khôi phục: so số bài viết, băm SHA-256 từng ảnh, đăng thử một bài mới.
- Bài và ảnh mất được so với RPO; lần nào thiếu dữ liệu ngoài RPO là không đạt.

Các chiến lược dự phòng

Sao lưu và khôi phục (backup and restore)

Chỉ giữ bản sao lưu; khi có sự cố mới dựng hạ tầng rồi khôi phục. Chi phí thấp nhất, RTO dài nhất. Đồ án gọi là dự phòng nguội.

Đèn mồi (pilot light)

Phần lõi như cơ sở dữ liệu chạy sẵn và liên tục nhận dữ liệu ở nơi dự phòng; phần còn lại chỉ dựng khi có sự cố.

Dự phòng ấm (warm standby)

Một bản thu nhỏ của toàn hệ thống chạy sẵn ở nơi dự phòng; khi có sự cố thì mở rộng để nhận toàn bộ tải. RTO ngắn hơn đèn mồi, chi phí cao hơn.

Chủ động - chủ động (active-active)

Nhiều nơi cùng phục vụ người dùng. RTO gần 0 với phần lớn sự cố, nhưng phức tạp và tốn kém nhất; phải chọn cách ghi để tránh xung đột khi nhiều nơi cùng ghi.

Ba cách đầu thuộc mô hình chủ động - bị động (active-passive): một nơi phục vụ, nơi kia chờ. Nguồn: AWS, Disaster recovery of workloads on AWS (2021).

So sánh các chiến lược

Chiến lược	Phần chạy sẵn	RTO tương đối	Độ phức tạp	Chi phí sẵn sàng
Sao lưu và khôi phục	Chỉ bản sao lưu	Dài nhất	Thấp nhất	Thấp nhất, chủ yếu tiền lưu trữ
Đèn mồi (pilot light)	Phần lõi, như cơ sở dữ liệu bản sao	Ngắn hơn	Thấp	Thấp
Dự phòng ấm (warm standby)	Bản thu nhỏ của toàn hệ thống	Ngắn	Trung bình	Trung bình
Chủ động - chủ động (active-active)	Toàn bộ hệ thống ở nhiều nơi	Gần 0	Cao nhất	Cao nhất

Nguồn: tổng hợp từ AWS, Disaster recovery of workloads on AWS (2021).

Các phương án khôi phục

Tình huống	Phương án	Lệnh
Mất namespace dr-api	Khôi phục tại chỗ về 1 giây trước sự cố từ bản sao lưu	restore-namespace.sh
Mất máy chính, chưa có cụm dự phòng ấm	Dự phòng nguội: dựng cụm mới, khôi phục từ bản sao lưu	failover-cold.sh
Mất máy chính, đang có cụm dự phòng ấm đã chạy	Dự phòng ấm: chuyển sang cụm dự phòng đang chạy	failover-warm.sh
Mất toàn bộ nhóm rg-dr-primary	Dự phòng nguội có chép ảnh từ bản ở Nhật, hoặc dự phòng ấm	DR_IMAGES_FROM_COPY=true failover-cold.sh hoặc failover-warm.sh

Các vòng diễn tập thử

Mã diễn tập	Tình huống	RTO	RPO	Kết quả	Lý do
Trial-D1-1	Mất namespace, khôi phục tại chỗ	Không đo được	Không đo được	Không đạt	Không tìm thấy bản sao lưu phù hợp.
Trial-D1-2	Mất namespace, khôi phục tại chỗ			Không đạt	Lỗi cú pháp json xử lý khi chọn bản sao lưu
Trial-D1-3	Mất namespace, khôi phục tại chỗ	74,0 giây	4,2 giây	Đạt	
Trial-D2-1	Mất máy chính, chuyển dự phòng nguội			Không đạt	Máy ảo Azure bị kẹt ở trạng thái starting
Trial-D2-2	Mất máy chính, chuyển dự phòng nguội	416,5 giây	6,4 giây	Không đạt	Kiểm tra phát hiện bị lỗi không ghi được ảnh
Trial-D2-3	Mất máy chính, chuyển dự phòng nguội	433,6 giây	42,8 giây	Không đạt	50 ảnh không được sao chép sang kho lưu trữ ảnh dự phòng
Trial-D2-4	Mất máy chính, chuyển dự phòng nguội	451,5 giây	41,6 giây	Đạt	

Các vòng diễn tập thử

Mã diễn tập	Tình huống	RTO	RPO	Kết quả	Lý do
Trial-D3-1	Mất máy chính, chuyển dự phòng ấm	247,2 giây	19,5 giây	Đạt	
Trial-D4-1	Mất toàn bộ nhóm tài nguyên			Không đạt	Lỗi quá trình sao chép ảnh không kết thúc
Trial-D4-2	Mất toàn bộ nhóm tài nguyên			Không đạt	Bị ràng buộc bởi chính sách sao chép cũ, lỗi sao chép ảnh vào kho dự phòng bị từ chối
Trial-D4-3	Mất toàn bộ nhóm tài nguyên	588,4 giây	18,1 giây	Đạt (đạt khi chấm lại)	16 ảnh không tải được thuộc bài đăng 17 đến 32 s trước sự cố, tức nằm trong RPO 5 phút. Luật chấm được sửa để phân biệt ảnh mất trong RPO với ảnh hỏng, chấm lại là đạt.
Trial-D5-1	Mất toàn bộ nhóm tài nguyên (ấm)	262,3 giây	47,0 giây	Đạt	

Kết quả vòng chính thức trên Azure

Tình huống	Lần đạt	RTO đo được (s)	RPO lớn nhất (s)
Mất namespace (D1)	3/3	73,8 - 74,6	3,5
Mất máy chính, dự phòng nguội (D2)	3/3	470,9 - 579,3	49,1
Mất máy chính, dự phòng ấm (D3)	3/3	256,1 - 265,7	18,5
Mất nhóm chính, dự phòng nguội (D4)	3/5	596,1 - 645,5	50,9
Mất nhóm chính, dự phòng ấm (D5)	3/3	258,1 - 265,7	45,2

Mục tiêu: RTO nguội 3.600 s, RTO ấm 600 s, RPO 300 s. 15/17 lần đạt, mọi lần đạt đều trong mục tiêu. D4-1, D4-2 không đạt do công cụ kiểm tra dừng, không phải do khôi phục.

Két chống xóa và khôi phục ngoài Azure

Kiểm tra hai tầng sao lưu dự phòng

- D6, két chống xóa (07/11/2026): bốn cách xóa và ghi đè gói 410 MB đều bị từ chối, kể cả với khóa tài khoản (HTTP 409 và 403). Lệnh rút ngắn thời hạn WORM cũng bị từ chối.
- D7, khôi phục từ két: tải gói về laptop, giải mã và khôi phục mất 1.201 s; số bài và mã băm khớp.
- D7, khôi phục từ máy chủ ngoài Azure: sau khi chép về laptop, khôi phục không gọi tới Azure mất 59 s; 1.026 bài, mã băm khớp, không thiếu ảnh.
- Kết quả: dữ liệu khôi phục được mà không cần kho sao lưu chính.

Chi phí thực hiện và vận hành của dự án

Chi phí sẵn sàng một tháng (730 giờ, giá bán lẻ Azure)

- Dự phòng nguội (chỉ lưu trữ bản sao lưu): khoảng 1 USD mỗi tháng.
- Dự phòng ấm (cụm dự phòng chạy suốt: máy, ổ đĩa, IP, lưu trữ): khoảng 44 USD mỗi tháng.
- Chọn dự phòng ấm khi thiệt hại do ngừng thêm khoảng 4 đến 6 phút mỗi lần sự cố, nhân số lần sự cố mỗi tháng, lớn hơn khoảng 43 USD; ngược lại chọn dự phòng nguội.
- Chi phí thật của toàn bộ thử nghiệm: 5,70 USD từ 25/09 đến 07/11/2026. Máy ảo 31,2 giờ 1,46 USD; truyền dữ liệu giữa hai vùng 1,08 USD; thao tác đọc, ghi kho lưu trữ 2,14 USD; IP tĩnh 0,68 USD; ổ đĩa 0,34 USD.

Kết luận

Kế hoạch chưa diễn tập không đạt; sau khi sửa thì đạt mục tiêu

- Vòng thử: 7/12 lần không đạt, mỗi lần lộ một lỗi mà đọc tài liệu không thấy (H4).
- Vòng chính thức: 15/17 lần đạt; RTO nguội lớn nhất 645,5 s, RTO ấm lớn nhất 265,7 s, RPO bài viết lớn nhất 50,9 s, đều trong mục tiêu (H1, H2, H3).
- Két chống xóa từ chối mọi cách xóa; dữ liệu khôi phục được từ két và từ máy chủ ngoài Azure (H5).
- Tổng chi phí thử nghiệm 5,70 USD; với web quy mô nhỏ như đồ án, dự phòng nguội là đủ.

Tài liệu tham khảo

Danh mục đầy đủ 33 nguồn nằm trong báo cáo

- M. Swanson et al., Contingency planning guide for federal information systems, NIST SP 800-34 Rev. 1, 2010.
- Amazon Web Services, Disaster recovery of workloads on AWS: recovery in the cloud, AWS Whitepaper, 2021.
- P. Krogh, The DAM Book: Digital Asset Management for Photographers, 2nd ed., O’Reilly Media, 2009.
- P. Ruggiero and M. A. Heckathorn, Data backup options, US-CERT, 2012.